

Email Phishing Analysis Report

1. Executive Summary

The analyzed email impersonates the **PayPal Billing Department** and attempts to convince the recipient to verify their account due to an allegedly unauthorized transaction.

The investigation identified several indicators of phishing, including **SPF, DKIM and DMARC authentication failures**, a sender domain that does not match the official PayPal domain, a different Return-Path domain, inconsistent URLs between the plain-text and HTML versions, an IP-address-based login URL, and urgency-based language threatening account suspension.

Based on the combined evidence, the email is classified as **PHISHING**.

2. Email Overview

Field	Finding
Claimed Sender	PayPal Billing Department
Actual Sender	billing@paypal-secure-alerts.com
Return-Path	freehostmail-svc.net
Sending IP	185.220.101.47
Classification	PHISHING
Primary Technique	Account verification phishing

3. Email Authentication Analysis

SPF

Result: FAIL

The sending IP address 185.220.101.47 was not authorized to send email on behalf of paypal-secure-alerts.com.

DKIM

Result: FAIL

The DKIM signature could not be successfully verified, indicating that the message failed the expected cryptographic authentication check.

DMARC

Result: FAIL

The message failed DMARC authentication/alignment. The header-from domain was paypal.com, while the authentication results did not provide valid alignment.

Assessment: The combined SPF, DKIM and DMARC failures are strong indicators that the email is not an authenticated PayPal message.

4. Sender and Domain Analysis

The email claims to originate from PayPal but uses the sender address:

billing@paypal-secure-alerts.com

This is not the official paypal.com domain.

The Return-Path also uses a different domain:

freehostmail-svc.net

The mismatch between the claimed organization, sender domain and Return-Path is suspicious and supports the phishing classification.

5. URL Analysis

Plain-Text Version

[https://www\[.\]paypal-secure-alerts\[.\]com/verify/account/confirm](https://www[.]paypal-secure-alerts[.]com/verify/account/confirm)

HTML Version

hxxp://185[.]220[.]101[.]47/pp-verify/login.php?session=88f2a1&acct=confirm

Do the two URLs match?

No.

The plain-text version points to paypal-secure-alerts.com, while the HTML version directs the recipient to the IP address 185.220.101.47.

The HTML link is particularly suspicious because it uses an IP address instead of an official PayPal domain and contains a /login.php path that appears designed to imitate an account-login or verification page.

6. Received Header Analysis

The relevant Received-header information indicates the following connection:

from [10.0.0.14] (unverified [185.220.101.47]) by mail-relay-19.freehostmail-svc.net with SMTP; Fri, 04 Sep 2026 10:12:01 +0000

The originating connection is shown as an unverified host and is inconsistent with the claimed PayPal identity. This provides additional evidence for investigation.

7. Social Engineering Analysis

The email uses **urgency and fear** to encourage the recipient to act without properly evaluating the message.

The email states that if the transaction was not authorized, the recipient must verify their account within **24 hours** or the account will supposedly be permanently suspended.

This is a common phishing tactic intended to pressure the recipient into clicking the link and potentially providing account credentials.

8. Indicators of Compromise (IOCs)

IOC Type	Indicator
Sender	billing@paypal-secure-alerts.com
Sender Domain	paypal-secure-alerts.com
Return-Path Domain	freehostmail-svc.net
IP Address	185.220.101.47
Suspicious Domain	paypal-secure-alerts.com
Plain-Text Version URL	hxxps://www[.]paypal-secure-alerts[.]com/verify/account/confirm
HTML Version URL	hxxp://185[.]220[.]101[.]47/pp-verify/login.php?session=88f2a1&acct=confirm

9. Evidence Summary

The phishing classification is supported by multiple independent indicators:

1. **SPF failure** — the sending IP was not authorized for the sender domain.
2. **DKIM failure** — the DKIM signature could not be verified.
3. **DMARC failure** — the message failed domain authentication/alignment.
4. **Sender-domain mismatch** — the email claims to be from PayPal but uses paypal-secure-alerts.com.
5. **Return-Path mismatch** — the Return-Path uses freehostmail-svc.net.
6. **URL inconsistency** — the plain-text and HTML versions contain different destinations.
7. **IP-based login URL** — the HTML version directs users to 185.220.101.47.
8. **Credential-related path** — /login.php suggests an attempt to obtain account credentials.

9. **Urgency** — the 24-hour suspension threat pressures the recipient to act quickly.

10. Verdict

Classification: PHISHING

The email exhibits multiple characteristics consistent with a phishing attempt, including failed email authentication, domain impersonation, inconsistent URLs, an IP-based login destination, and urgency-based social engineering.

11. Recommended Actions

For the Recipient

- Do not click the links or provide credentials.
- Report the message as phishing and delete it.
- If concerned about a PayPal transaction, access PayPal through the official website or trusted application rather than using the email link.
- If credentials were entered, change the password immediately.
- Enable MFA where available.
- Report the incident to the relevant IT/security team.

For a SOC/Security Team

- Block or investigate the identified sender domain and IP address.
- Add confirmed malicious indicators to appropriate security controls.
- Search mail logs for other recipients who received the same message.
- Check whether any users clicked the URLs.
- If credentials may have been submitted, initiate account security and credential reset procedures.
- Monitor affected accounts for suspicious authentication activity.

12. Conclusion

The analyzed email demonstrates several characteristics consistent with a phishing campaign targeting PayPal users.

The combination of **SPF, DKIM and DMARC failures, sender/domain inconsistencies, suspicious URL behavior, an IP-based login destination, and urgency-based social engineering** provides sufficient evidence to classify the email as phishing.

13. Investigation Summary

This investigation demonstrates an email-security analysis workflow covering:

- Email-header authentication analysis
- SPF, DKIM and DMARC verification
- Sender and domain validation
- Return-Path analysis
- URL comparison between plain-text and HTML versions
- Received-header analysis
- Social-engineering identification
- IOC extraction
- Phishing classification
- Recommended response and containment actions

This project demonstrates practical exposure to **email threat analysis and SOC investigation techniques** relevant to an entry-level SOC Analyst role.